

UNIVERSIDAD DE LOS ANDES

ISIS 2311 — Redes y Servicios de Comunicaciones

Contexto. AlpesPay es un sistema ficticio, creado con fines exclusivamente pedagógicos para este curso; no corresponde a ninguna entidad real, la actividad consiste en capturar el tráfico del laboratorio, deducir su protocolo binario sobre WebSocket, implementar un cliente propio y emplearlo para ejecutar operaciones que la interfaz no ofrece; el progreso se compone de siete resultados verificables reflejados en el marcador del curso.

Plazo. La actividad se completa a más tardar el domingo 4 de octubre de 2026 a las 11:59 pm. No se reciben entregas ni se contabilizan resultados posteriores a esa fecha.

Alcance. El alcance se limita exclusivamente al sitio del laboratorio AlpesPay indicado por el profesor y a la cuenta del equipo propio y queda prohibida cualquier acción sobre otros hosts, redes, servicios o infraestructura, así como cualquier intento de degradar la disponibilidad del laboratorio o de afectar a otros equipos. La actividad se resuelve reproduciendo el protocolo, no atacando la infraestructura.

Código de ética. Al firmar, el equipo declara que:

1. Actúa con honestidad académica y no suplanta, copia ni presenta como propio el trabajo de otro equipo.
2. Se mantiene dentro del alcance definido y no emplea las técnicas aprendidas contra sistemas ajenos ni fuera de este laboratorio.
3. No divulga ni comparte soluciones, tokens, credenciales u otro material del reto con equipos distintos al propio.
4. No hace uso de técnicas de fuerza bruta ni intenta malogar/explotar el cliente web.

Aceptación. La entrega de esta actividad supone la aceptación plena del alcance, el código de ética y la declaración anteriores.

Equipo: _____ · Fecha: _____

Nota: Establecer un correo electrónico puede ayudar durante el proceso. Se recomienda revisar la bandeja de entrada/SPAM.

ENTREGABLES Y EVALUACIÓN

La entrega se compone de los elementos siguientes.

- **Cliente propio** (código fuente) que reproduce el protocolo. Puede partir del esqueleto entregado (`plantilla_cliente.py` + `ws_cliente.py`), usar una librería de WebSocket, o implementar el handshake y el framing sobre un socket TLS. (Entrega en BN)
- **Registro de sesión** con el token que el servidor emite para cada uno de los siete resultados. (Contabilizado por el backend)

Nota: Un resultado sin su token de servidor no se contabiliza. Los tokens son específicos de la cuenta del equipo.
--

ALPESPAY

PROTOCOLO DE SERVICIOS INTERNOS MANUAL DE REFERENCIA

Documento recuperado de respaldo (reconstruido) · v0.9

VISIÓN GENERAL

AlpesPay es una banca en línea. El panel web no almacena datos: delega toda operación en dos servicios internos que se comunican por un único canal binario sobre WebSocket. Los mensajes no son texto estructurado: son secuencias de bytes. El presente documento describe el sistema en la medida en que pudo recuperarse.

La estructura de las tramas, los identificadores de operación, los tamaños y el orden de los campos y el algoritmo de la suma de verificación no se especifican en este documento. Cada uno se determina por observación del tráfico real del sistema. Su ausencia es deliberada e indica el punto en que el protocolo se reconstruye.

El progreso se compone de siete resultados verificables reflejados en el marcador del curso. Cada resultado se acredita con un token que emite el servidor.

Nota: Los bloques como este aparecen a lo largo del manual para señalar comportamiento excepcional, remitir a otro documento o declarar aquello que este documento no describe.

Nota: El sistema descrito es ficticio y existe con fines del curso ISIS 2311. AlpesPay no corresponde a ninguna entidad real.

Nota: El texto procede de un respaldo dañado. Los elementos que no se documentan aquí se establecen contra una captura del tráfico. El procedimiento de captura se describe en el capítulo SUBSISTEMA DE CAPTURA.

CÓMO SE INTERACTÚA CON EL SISTEMA

La interacción con los servicios internos se realiza EXCLUSIVAMENTE mediante un cliente propio que hable el protocolo. El panel web es la banca legítima: sirve para operar la cuenta y comprobar el efecto de las acciones (saldo, movimientos), pero no expone las operaciones del reto. Los siete resultados solo se obtienen desde el cliente propio.

El transporte es WebSocket sobre TLS. El equipo escribe su propio cliente del protocolo: puede partir del esqueleto entregado, apoyarse en una librería de WebSocket, o implementar el handshake y el framing sobre un socket TLS. Un socket TCP o UDP crudo que envíe los bytes del protocolo, sin TLS ni WebSocket, no funciona.

Nota: Se entrega un esqueleto de partida, `plantilla_cliente.py`, que reutiliza `ws_cliente.py` para resolver la capa WebSocket (TLS, handshake y framing) y expone un canal para enviar y recibir bytes. Sobre ese canal el equipo implementa el protocolo deducido de la captura; el esqueleto no incluye el protocolo.

Nota: Cada resultado, al lograrse contra el servidor, devuelve un token de verificación específico de la cuenta del equipo. Ese token es la evidencia del resultado; sin token no se contabiliza. No existe un marcador público de progreso para los estudiantes.

ARQUITECTURA Y ORGANIZACIÓN DEL SISTEMA

El panel web no conserva estado. Cada acción del panel se traduce en uno o más mensajes hacia los servicios internos. El sistema expone dos servicios internos: uno de cuentas y uno de vales. Cada mensaje se dirige a uno de ellos; la forma en que se identifica el servicio destino se determina contra la captura.

Todo entero del protocolo se codifica en big-endian. El formato del resto de cada mensaje difiere entre servicios.

El servicio de cuentas emite, en la operación de inicio de sesión, un identificador de sesión de longitud reducida. Ese identificador acompaña, sin modificación, a las operaciones subsiguientes del mismo servicio.

Nota: Un envío no corresponde a una recepción. Los mensajes se entregan concatenados o fragmentados. La delimitación de cada mensaje se determina contra la captura.
--

SERVICIO DE CUENTAS

En este capítulo, <TOKEN> designa el identificador de sesión. La operación de inicio de sesión emite <TOKEN>; las operaciones subsiguientes lo repiten sin modificación.

El servicio de cuentas atiende, entre otras, las operaciones de anuncio del cliente, inicio de sesión, consulta de saldo, transferencia entre cuentas y abono de vales.

La estructura de la trama —identificador de servicio, identificador de operación, banderas, longitud y contenido—, el repertorio de operaciones y la relación entre cada respuesta y su solicitud se determinan contra la captura.

El saldo se expresa en centavos.

Nota: El servicio atiende operaciones de dev/debug que no figuran en su catálogo. Una operación no listada responde si se invoca su identificador de operación.

SERVICIO DE VALES

El servicio de vales no emplea la cabecera del servicio de cuentas. Cada mensaje es un bloque único. El servicio emite un vale a solicitud.

El vale es un bloque de tamaño fijo. Entre sus campos se incluye una suma de verificación. El orden y el tamaño de los campos se determinan contra vales capturados. Un vale se abona a una cuenta a través del servicio de cuentas.

FIRMA

El vale incluye una suma de verificación que no emplea clave secreta. El algoritmo y sus parámetros se determinan a partir de un conjunto de vales capturados; cada vale relaciona su contenido con su suma.

Nota: Los parámetros de la suma son específicos de cada cuenta. La determinación emplea exclusivamente vales emitidos para la cuenta del equipo propio. Este documento no incluye vector de verificación.

SUBSISTEMA DE CAPTURA

En este capítulo, <host> designa la dirección del laboratorio.

El tráfico del sistema viaja cifrado con TLS. Una captura directa muestra únicamente datos de aplicación ilegibles. El descifrado no emplea la clave privada del servidor: requiere las claves de sesión TLS del cliente, obtenidas mediante la variable de entorno SSLKEYLOGFILE.

1. Claves de sesión TLS

Cuando un navegador se lanza con SSLKEYLOGFILE definida, las claves de sesión negociadas en cada handshake se escriben en el archivo indicado. El archivo se llena solo con las conexiones abiertas mientras la variable está definida.

Nota: La captura precede a la apertura o recarga del panel. El descifrado requiere el handshake TLS dentro de la captura. Una sesión ya establecida no se descifra y se recarga.

2. Uso

La herramienta de captura monta el proceso completo y abre el resultado descifrado. La dirección del laboratorio se toma por omisión; una dirección distinta se pasa como argumento.

Comando	Glosa
tools/capturar-mac.sh	La captura se lanza en macOS con la dirección del laboratorio por omisión.
tools/capturar-win.ps1	La captura se lanza en Windows a través de PowerShell.
tools/capturar-mac.sh https://<host>/	Una dirección distinta se pasa como argumento.

En el procedimiento manual, la clave se declara en Wireshark en Preferences → Protocols → TLS → (Pre)-Master-Secret log filename. La captura se inicia en la interfaz por la que se alcanza el laboratorio, con el filtro tcp port 9010. El panel se recarga después de iniciar la captura.

3. Verificación del descifrado

Con el filtro de visualización websocket, la aparición de tramas de aplicación legibles indica que el descifrado se aplicó. La ausencia de tramas WebSocket indica que el handshake no quedó dentro de la captura, que la clave no está declarada, o que la sesión ya estaba abierta.

Nota: Un cliente propio exporta sus propias claves de sesión cuando el intérprete se enlaza con OpenSSL 1.1.1 o superior. El intérprete de fábrica de macOS se enlaza con LibreSSL y no exporta claves; en su lugar se emplea un intérprete con OpenSSL y la variable SSLKEYLOGFILE definida.

PARÁMETROS NO DETERMINADOS EN ESTE DOCUMENTO

Los elementos siguientes no se especifican en este documento. Cada uno se determina por observación del tráfico capturado. Su ausencia es deliberada e indica el punto en que el protocolo se reconstruye.

Entidad	Cómo se determina
Estructura de las tramas (todos los servicios)	se determina contra la captura.
Identificadores de servicio y de operación	se determinan contra la captura.
Tamaños y orden de los campos (cuentas y vales)	se determinan contra la captura.
Relación entre solicitud y respuesta	se determina contra la captura.
Algoritmo y parámetros de la suma de verificación	se determinan a partir de vales capturados; son específicos de cada cuenta.
Operaciones no listadas (dev/debug)	se determinan probando el servidor.
Validación del origen frente al titular del token	se determina probando el servidor.

Nota: Un capítulo documenta únicamente aquello que el documento no describe. La ausencia de una definición es información.

CONDICIONES DE OPERACIÓN

1. Alcance

Se interviene únicamente el servicio AlpesPay del laboratorio y la cuenta del equipo propio. El ejercicio se resuelve reproduciendo el protocolo. No requiere degradar la infraestructura ni intervenir otras máquinas.

2. Resultado

El resultado consiste en un cliente propio que reproduce el protocolo y ejecuta operaciones que el panel no ofrece, junto con el registro de los hallazgos. El avance se refleja en el marcador como un conteo de siete.

3. Marcador

Cada resultado, al alcanzarse contra el servidor, emite un token de verificación asociado a la cuenta del equipo. Ese token constituye la evidencia del resultado. Un resultado sin su token no se contabiliza.

Nota: Referencia de trabajo: el ciclo de captura, hipótesis y verificación descrito en el manual del estudiante fija el método. El presente documento fija lo que del protocolo se recupera de la captura.
--